DAY 30 | POST-READ

# Security and Guardrails: Recap and Beyond

What we covered today, plus ideas to stretch your understanding.

Prepared by **Ahmed** | linkedin.com/in/ahmed-al-imaad

## Part A: Summary of today

| Topic | What to remember |
|---|---|
| OWASP LLM risks | Prompt injection, sensitive information disclosure, system prompt leakage, excessive agency, improper output handling, misinformation, unbounded consumption and more. |
| OWASP agentic risks (NEW v4) | Goal hijack, tool misuse, identity and privilege abuse, supply chain, memory poisoning, cascading failures and more. |
| Indirect injection (NEW v4) | Instructions hidden in retrieved content, tool results, markup or memory. |
| Defence in depth | Input checks, context tagging, instruction hierarchy, output filters, action limits. |
| Brownfield with Codex (NEW v4) | Characterisation tests first, a plan, small reviewed steps, scans after each. |
| Agent identity (NEW v4) | Own ID, scoped, short-lived, audience-bound, revocable tokens; audit every call. |
| Approval gates | Auto for low risk, review for medium, approval for high, block unknown tools. |
| Red team + report v3 (NEW v4) | Attacks and benign twins as tests; findings, fixes and evidence in report v3. |
| Responsible AI | Fairness, transparency, privacy, accountability, safety, human oversight. |

## Part B: Going beyond today

### 1. Moderation APIs and safety classifiers

Providers offer moderation endpoints and safety classifiers that flag harmful content. Combine them with your own business rules; neither alone is enough.

### 2. Malicious skills and MCP servers

In early 2026 an audit of public agent skills found some that carried hidden instructions or exfiltration code. Treat every skill, plugin and MCP server like a dependency: pin versions, review the source, run it with the least permissions, and scan it.

### 3. Monitoring unsafe outputs

Count blocked inputs, quarantined documents and redacted outputs per day. A sudden rise is an attack or a bug. You will build the dashboards on Day 35.

### 4. Data residency and privacy law

Customers in India and Japan may need data to stay in-country and to follow laws such as India's Digital Personal Data Protection Act and Japan's Act on the Protection of Personal Information. Confirm requirements with the customer's legal and security teams.

### 5. Incident response for AI

Have a plan: how to switch features off, revoke agent tokens, notify people, review logs, and tell affected users. Practise it before you need it.

## Part C: Check yourself

- Why is indirect injection especially dangerous for RAG and agents?
- Why is removing secrets from the prompt better than telling the model not to reveal them?
- Name three properties of a safe agent token.
- Why write characterisation tests before asking Codex to change legacy code?
- How would you measure false alarms in an injection detector?

## Part D: Practice ideas for tonight

- Add five new attack prompts and five tricky benign prompts to the red-team suite.
- Add two indirect-injection cases hidden in tool results.
- Write a one-page AI incident response checklist for your capstone.

**Coming up on Day 31:** evaluating GenAI systems: faithfulness, RAG evaluation, agent trajectory evaluation and security regression evals.

Otsukaresama deshita (お疲れ様でした): thank you for your hard work today